

11. Seguridad

AI Dataset Foundry
Versión 0.2.0
2026-09-10
Fuente: 11-security.md

11. Seguridad

La aplicación procesa entradas potencialmente hostiles con privilegios del usuario local. No es un sandbox ni un servicio multiusuario. No implementa autenticación, autorización, roles, sesiones, cifrado en reposo, firma de datasets, DLP, antivirus ni auditoría inmutable. El control arquitectónico principal es ejecutar localmente y enlazar la UI a 127.0.0.1.

Controles implementados

- Basename y validación de segmentos contra path traversal en uploads/descargas.
- Límite de 50 MiB por upload web y limpieza de la corrida ante error.
- SHA-256 de fuente y contenido para identidad/trazabilidad, no autenticidad.
- Regex auxiliares para claves AWS, secretos asignados y claves privadas; emails se señalan.
- Clone Git temporal/shallow y filtro de extensiones.
- Android sin permiso Internet según manifest; Actions fijadas a SHA.

Superficie y controles ausentes

Riesgo	Evidencia	Mitigación recomendada
SSRF/red interna	load_url acepta URL elegida	allowlist, bloqueo IP privada/link-local y redirects
Parser hostil/zip bomb	PDF/DOCX en proceso principal	workers aislados y límites CPU/memoria/tiempo
Exposición HTTP	API sin auth	mantener loopback; auth/TLS si cambia el alcance
CSRF/CORS	sin protección explícita	origen estricto y token para alcance compartido
Retención	work/ui-runs sin limpieza	TTL, cuotas y borrado seguro
PII/secretos	detector heurístico	DLP especializado y revisión humana
Supply chain Git	clona HEAD sin pin	commit pin, firma y budgets
DoS local	Git/directorios sin presupuesto	cuotas de archivos/bytes/tiempo
Fuga en errores	str(exc) en API/manifest	errores tipados y redactados

No se realizaron ataques destructivos. Vulnerabilidades concretas requieren pip-audit/Dependabot fechados. Derechos de corpus, base legal, minimización y retención requieren validación humana. Consulte SECURITY.md y docs/GOVERNANCE.md.